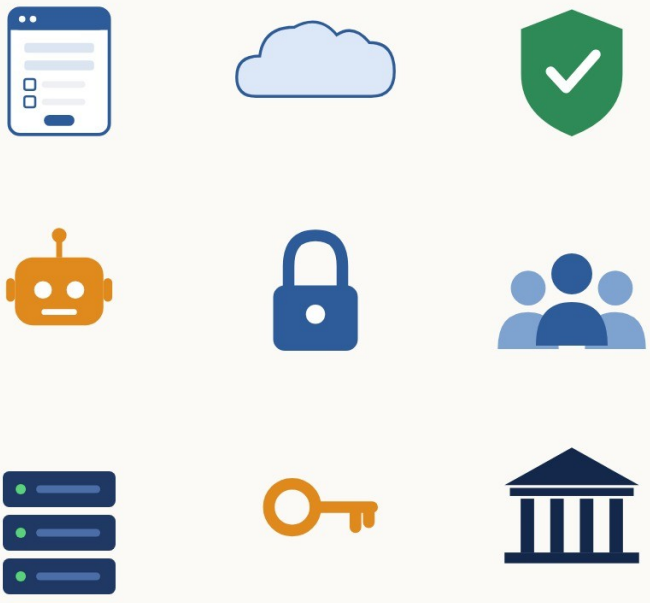
국민 · 공공기관 · 기업을 위한 백서

AI 시대,
설문·신청서가
해킹의 문이 됩니다

설문·신청·수집 단계의 보안 위협과 대응



2026. 11. 10.

한국컨설팅산업재단 | 개인정보보호진흥원

발간번호 2026-11-02

발 간 사

"내 개인정보가 또 새어 나갔다" 는 소식이 더는 낯설지 않습니다. 올해에도 대통령 전용기 탑승자 명단이 외부 사이트에 노출되었고, 공직자 10 만여 명의 정보가 외주업체의 옛 서버에서 유출되었으며, 수많은 기업이 함께 쓰는 업무 프로그램까지 해킹되었습니다. 피해는 언제나 정보의 주인인 국민에게 돌아옵니다.

(재)한국컨설팅산업재단 부설 개인정보보호진흥원은 국민이 자신의 개인정보에 대한 권리를 제대로 누릴 수 있도록, 그리고 그 권리를 지킬 현실적인 방법을 찾기 위해 노력하고 있습니다. 공공기관이 온라인으로 개인정보를 어떻게 받고 있는지 직접 진단해 개선을 권고하고, 보안인증을 받은 안전한 조사 도구를 공공기관이 쉽게 쓸 수 있도록 지원하는 사업도 추진하고 있습니다.

이 백서는 우리가 매일 무심코 작성하는 설문지와 신청서에 주목했습니다. 채용 지원, 교육·행사 신청, 만족도 조사처럼 국민의 정보가 기관으로 처음 들어가는 바로 그 길목입니다. 너무 흔해서 오히려 보안의 사각지대가 되기 쉬운 이곳이, 빠르게 발전하는 AI 해킹 앞에서는 가장 먼저 두드려질 수 있는 문이 됩니다.

그래서 이 백서는 설문·신청서가 어떻게 해킹의 통로가 될 수 있는지 14 가지 경로로 나누어 그림과 함께 쉽게 풀어 썼습니다. 이미 일어난 일과 앞으로 일어날 수 있는 일을 구분했고, 기관과 기업이 무엇을 바꿔야 하는지, 국민 한 사람 한 사람이 무엇을 지키면 되는지도 담았습니다.

이 백서가 국민 여러분께는 내 정보를 지키는 생활 안내서가, 기관과 기업에는 안전한 정보 수집으로 나아가는 길잡이가 되기를 바랍니다. 사고가 난 뒤에 고치기보다, 문을 미리 단단히 하는 일이 모두를 지키는 가장 좋은 방법입니다.

2026 년 11 월

한국컨설팅산업재단 이사장 정 옥 래

발간기관 소개

개인정보보호진흥원

국민 개인정보 안심센터 — 현장을 진단하고, 실행할 수 있는 대안을 찾습니다

(재)한국컨설팅산업재단 부설

OUR ROLE

정보주체인 국민의 권리를 지키는 민간 공익 개인정보 보호 기구

- 컨설팅
- 교육
- 정책연구
- 포럼

개인정보보호진흥원은 (재)한국컨설팅산업재단의 대표 중점 사업으로, 컨설팅·교육·정책연구·포럼 활동을 종합적으로 수행합니다. 공공기관의 온라인 개인정보 수집 실태를 같은 기준으로 진단해 개선을 권고하고, 보안인증을 받은 도구가 현장에 자리 잡도록 지원하며, 현장의 근거를 정책 논의로 잇고 있습니다.

민간 공익기구입니다

진흥원은 정부 규제기관이 아니며, 조사 결과만으로 위법이나 유출을 단정하지 않습니다.

주요 사업 WHAT WE DO

01 · RESEARCH

실태조사·분석

SURE-CHECK로 공공기관의 온라인 신청·설문 화면을 같은 기준에서 진단하고, 결과를 공개해 개선을 권고합니다.

02 · EDUCATION

교육·웨비나

강화된 개인정보 보호법에 맞춰 공공기관·기업 실무자가 바로 적용할 수 있는 대응 교육을 운영합니다.

03 · DIFFUSION

인증도구 보급·확산

클라우드 보안인증(CSAP)을 받은 온라인 조사 도구를 공공기관·협단체 등이 부담 없이 쓰도록 무상 지원합니다.

04 · MONITORING

개인정보 지키미 모니터링단

국민이 직접 참여해 생활 속 개인정보 수집 화면을 살피는 모니터링단을 준비하고 있습니다.

일하는 방식 HOW WE WORK

STEP 1 · 진단

수집 화면 전수 진단

SURE-CHECK · 전문가 재확인

→

STEP 2 · 권고·지원

개선 권고와 실무 지원

교육·웨비나 · 인증도구 보급

→

STEP 3 · 정책 제언

현장 근거를 정책으로

정책연구 · 국정감사 자료 제공

개인정보보호진흥원

주요 활동

01 공공기관 온라인 개인정보 수집 실태 전수조사

1,347개	149건	98.7%	87.5%
공공기관 홈페이지	보안인증 없는 도구로	안전조치 안내 미흡	개선 권고 수용·개선
개인정보 수집 화면 진단	개인정보를 수집하던 설문	149건 중 147건	회신 40곳 중 35곳

조사 결과의 활용

- **정책연구** — 연구 보고서·정책 제언의 근거 자료
- **국정감사** — 국회 국정감사 자료 제공
- **결과 공개** — 기관별 개선 권고와 결과 공개

02 개인정보 보호 웨비나

강화된 개인정보 보호법에 맞춰 공공기관·기업 실무자가 무엇을 바꿔야 하는지 사례 중심으로 안내합니다. 설문·신청서 등 온라인 수집 단계의 안전조치와 보안인증 도구 활용 방법을 함께 다룹니다.

PARTICIPATION

860개+

웨비나 참가 신청 기관·기업

CONTACT

개인정보보호진흥원

서울특별시 송파구 양재대로71길 20-30, 2층

02-501-2906
전화

cs@kcf-korea.org
이메일

02-558-5146
팩스

www.kcf-korea.org/privacy-center
웹사이트

진흥원 바로가기

운영 법인

(재)한국컨설팅산업재단

Since 2010 · 공익법인 제4318호

"대한민국 지식서비스산업을 선도하는 공익법인" · 산업통상자원부 허가 재단법인
전국상업경진대회(NBO) 사무국 · 기업 컨설팅 교육 · 청소년 경영교육 · 개인정보보호진흥원
T 02-555-9091 · F 02-455-0090 · www.kcf-korea.org

※ 수치는 진흥원 공개 자료 기준(2026)

이 백서를 읽는 법

핵심 입장

폼에서 시작해 내부 서버까지 장악된 공개 사례는 아직 없지만, AI 해킹 기술의 발전을 고려할 때 충분히 발생 가능하며, 선제적 예방이 반드시 필요합니다.

세 가지 표시 각 경로에는 아래 표시 중 하나를 붙였습니다. 이미 일어난 일과 앞으로 일어날 수 있는 일을 한눈에 구분하기 위해서입니다.

● 국내 발생

우리나라에서 실제로 일어났습니다

사고·감독기관 처분·
정부 발표로 확인

해외 발생

해외에서 실제로 일어났습니다

해외 사고, 또는 실제 서비스에서
확인된 같은 원리의 공격

⚠ 발생 가능성 높음

공개 사례는 없지만 충분히 가능

필요한 기술과 재료가
이미 모두 확인된 경로

'국내 발생'·'해외 발생'은 그 경로의 핵심 단계가 실제로 확인됐다는 뜻이며, 모든 사고가 설문지에서 시작됐다는 뜻은 아닙니다. '발생 가능성 높음'은 확률을 계산한 것이 아니라, 관련 기법이 이미 확인돼 미리 막아야 한다는 판단입니다.

자료 범위

이 백서는 언론 보도와 정부 발표로 **공개된 사고만** 다뤘습니다. 알려지지 않은 사고까지 더하면 실제 피해는 더 클 수 있습니다.

인용한 자료는 모두 원문을 직접 확인했습니다. 공격 방법은 이해를 돕는 수준으로만 설명했고, 실제 공격에 쓸 수 있는 세부 절차는 싣지 않았습니다.

이 백서에서 쓰는 말	뜻
폼	설문·신청·접수에 쓰는 온라인 양식. 구글폼·네이버폼 같은 무료 외부 서비스가 대표적입니다.
클라우드 보안인증 도구	국가가 미리 보안을 점검해, 공공기관이 써도 된다고 확인한 클라우드 서비스(6 부에서 자세히 설명).
외주(위탁)	기관이 설문·채용·행사·교육 같은 일을 다른 업체에 맡기는 것.
SaaS	설치하지 않고 인터넷으로 빌려 쓰는 소프트웨어 서비스(예: 클라우드 ERP, 설문 서비스).
AI 비서	메일·문서·응답을 읽고 요약·정리해 주는 업무용 AI.

차례

이 백서를 읽는 법 5
한눈에 보는 숫자 7
핵심 요약 8
1 부. 왜 설문·신청서인가 9
가장 넓게 열린 문 10
AI 가 해킹을 바꿨습니다 11
14 개 해킹 침투경로 한눈에 12
2 부. 기관이 직접 폼을 쓸 때 13
해킹 침투경로 1 설정 하나 잘못으로 남의 응답이 보입니다 14
해킹 침투경로 2 폼 주인 계정이 털리면 응답이 통째로 넘어갑니다 15
해킹 침투경로 3 진짜 공식 폼이 '가짜'로 바뀝니다 16
해킹 침투경로 4 기관을 사칭한 가짜 신청서가 국민을 속입니다 17
해킹 침투경로 5 응답 속에 숨긴 명령이 AI 비서를 조종합니다 18
해킹 침투경로 6 첨부파일 하나가 내부 서버까지 이어집니다 19
해킹 침투경로 7 새어 나간 명단이 AI 맞춤 피싱의 재료가 됩니다 20
3 부. 외주를 맡길 때 21
해킹 침투경로 8 외주업체 PC·계정 하나로 여러 기관 자료가 털립니다 22
해킹 침투경로 9 끝난 사업의 자료가 외주업체에 남아 있다가 털립니다 23
해킹 침투경로 10 외주업체가 원본 파일을 외부 사이트에 올립니다 24
해킹 침투경로 11 납품 파일과 '연동 앱' 승인으로 기관 안까지 들어옵니다 25
해킹 침투경로 12 외주업체의 원격접속 계정으로 원청 내부망에 들어옵니다 26
업무 특성에 따른 우선 점검 대상: 어디부터 살펴야 하나 27
4 부. 민간 기업과 플랫폼 29
해킹 침투경로 13 SaaS 플랫폼 한 곳이 뚫리면 고객사 전체가 피해를 봅니다 30
해킹 침투경로 14 계정 거래와 '전화 사칭'으로 기업 자료가 대량 반출됩니다 31
5 부. 기술적 근거 32
6 부. 해법: 국가가 검증한 클라우드 도구 35
클라우드 보안인증이란 36
무엇이 다른가 37
보안인증 도구는 이렇게 해킹을 막습니다 38
방어막 ① 계정 통제: 비밀번호가 새도 쉽게 못 들어옵니다 39
방어막 ② 공개·수정 통제: 설정 실수와 바꿔치기를 막습니다 39
방어막 ③ 보관·분리: 자료가 국내 전용 공간에만 있습니다 40
방어막 ④ 파일 처리: PC 감염 고리를 약하게 만듭니다 40
방어막 ⑤ 감시·사고 대응: 조용한 침입을 찾아냅니다 41
방어막 ⑥ 국가 검증: 국가가 미리, 그리고 매년 확인합니다 41
침투경로별 방어 지도 42
공공은 의무, 민간은 적극 도입 43
인증도 만능은 아닙니다 43
7 부. 기관·기업이 할 일 44
세 가지 대안 45
단계별 실행 로드맵 46
외주 계약: 강제인가, 당연한 조건인가 47
정책 제언 48
8 부. 국민 행동 지침 49
맺음말 51
부록 A. 용어 풀이 52
부록 B. 출처 53

한눈에 보는 숫자

설문·신청·수집 단계에서 이미 일어난 일들입니다. 숫자 하나하나가 '기관 밖에 놓인 정보'가 얼마나 쉽게 새는지 보여 줍니다.

국내 실태
149건
보안인증 없는 외부 폼으로 개인정보를 받던 공공기관 설문
137개 기관 · 2026년 실태조사

국내 발생
11만 2,890개
비정상 로그인·비밀번호 무단 변경 피해를 본 학교 교육용 구글 계정
2026년 10월

국내 발생
10만 4,139명
'파기 완료'라던 외주업체 옛 서버에서 유출된 공직자 정보
2026년 9월

국내 발생
11만 곳 이상
해킹된 더존 ERP (스마트A10)를 쓰는 기업 수(회사 측)
2026년 10월

국내 발생
237만 건
SaaS 업체 한 곳이 뚫려 고객사 22곳에서 신고된 유출
2026년 9~10월

국내 발생
168명
외주업체 업로드 정황으로 약 5개월간 노출된 대통령 전용기 명단
2026년 11월 · 정부 조사 중

해외 발생
80~90%
해킹 작업 가운데 AI가 스스로 수행한 비율
2025년 11월 공개

막는 방법의 효과
0명
보안키를 쓴 사용자 중 표적 피싱 피해자
구글 공동연구 · 2019년

출처: 149 건[1] · 11 만 2,890 개[2] · 10 만 4,139 명[3] · 11 만 곳 이상[4] · 237 만 건[5] · 168 명[6] · 80~90%[7] · 0 명[8]

핵심 요약

1

설문·신청서는 가장 넓게 열린 문입니다.

모든 기관과 부서가 1 년 내내 만들고, 모르는 사람의 입력과 파일을 일부러 받습니다. 공공기관 137 곳이 개인정보를 받는 설문 149 건을 보안인증 없는 외부 폼으로 운영하고 있었습니다.

2

AI 가 해킹의 속도와 규모를 바꿨습니다.

해외에서는 해킹 작업의 80~90%를 AI 가 수행한 사례가 확인됐고, 국내에서도 AI 로 만든 가짜 신분증 피싱이 나타났습니다. 예전에는 손이 많이 가 지나치던 작은 문까지 한꺼번에 두드릴 수 있게 됐습니다.

3

14 개 해킹 침투경로 가운데 9 개는 핵심 단계가 이미 실제로 확인됐습니다.

나머지 5 개는 공개 사례는 없지만 관련 공격 기법이 이미 확인됐고, 일이 터지면 피해가 커서 미리 막아야 하는 '발생 가능성 높음' 경로입니다. 특히 첨부파일에서 내부 서버로 이어지는 경로는 중간 단계들이 국내에서 실제로 일어났습니다.

4

외주와 SaaS 가 피해를 몇 배로 키웁니다.

'파기 완료' 라던 외주업체 옛 서버에서 공직자 10 만여 명의 정보가 유출됐고, 11 만 곳 이상의 기업이 쓰는 ERP 와 고객사 22 곳이 쓰던 서비스가 연달아 뚫렸습니다.

5

해법은 문을 '국가가 검증한 문' 으로 바꾸는 것입니다.

공공기관은 클라우드 보안인증 도구 사용이 의무이고, 민간도 적극 도입해야 합니다. 꼭 필요한 기능을 갖춘 인증 도구는 14 개 중 12 개 침투경로에 대응하고, 그중 10 개는 위험을 크게 줄이거나 경로를 막을 수 있습니다(연구진 판단). 외주 계약에도 같은 조건을 넣고, 국민은 10 가지 수칙으로 스스로를 지킬 수 있습니다.

Part 1.

왜 설문·신청서인가

모든 기관이 매일 여는 문, 그리고 AI 가 바꾼 해킹



가장 넓게 열린 문



국민 · 지원자 · 업체 … 그리고 섞여 들어오는 공격자

어디에나
모든 기관, 모든 부서가
1년 내내 새 폼을 만듭니다

누구에게나
로그인 없이 '모르는 사람의 입력'을
일부러 받는 거의 유일한 창구입니다

무엇이든
글과 숫자뿐 아니라
파일까지 받습니다

그래서 AI 해킹이 가장 먼저 두드릴 수 있는 문입니다

설문·신청서는 어느 한 부서만의 일이 아닙니다. 채용, 교육, 행사, 민원, 공모전, 만족도 조사까지 거의 모든 부서가 1년 내내 새 폼을 만듭니다. 2026 년 공공기관 1,347 곳을 진단한 결과, **137 개 기관이 개인정보를 받는 설문 149 건을 보안인증 없는 외부 폼으로 운영**하고 있었습니다. 구글폼이 90 건, 네이버폼이 47 건이었고, 주민등록번호나 건강·장애 정보를 받는 폼도 10 건 있었습니다[1].

※ 진흥원은 공개된 설문 화면을 자동진단도구(SURE CHECK)로 진단하고 전문가가 다시 확인했습니다. 응답자료는 열어 보지 않았고, '안내 미흡' 은 화면에 적힌 안내를 기준으로 판단한 것으로 기관 내부의 보안조치까지 확인한 것은 아닙니다. 결과 통보 뒤 회신한 40 개 기관 중 35 곳(87.5%)이 수용·개선했습니다.

폼은 기관 시스템 가운데 로그인 없이 **'모르는 사람의 입력' 을 일부러 받는 거의 유일한 창구**입니다. 글과 숫자뿐 아니라 파일도 받습니다. 공격자에게 이보다 넓고 자연스러운 입구는 드뭅니다. 그래서 이 백서의 출발점은 하나입니다. 사고가 난 뒤 막는 것이 아니라, **밖에서 들어오는 문부터 먼저 지켜야 합니다.**

AI 가 해킹을 바꿨습니다



AI가 공격에 들어오는 네 곳



2025 년 11 월, AI 기업 Anthropic 은 국가 배후로 추정되는 조직이 자사의 AI 코딩 도구를 자동화 도구로 써서 기술기업·금융기관·정부기관 등 약 30 곳에 침투를 시도했다고 밝혔습니다. **공격 작업의 80~90%를 AI 가 수행**했고, 사람은 캠페인마다 4~6 번의 중요한 결정만 내렸습니다. 일부 공격은 성공했습니다. AI 가 없는 계정정보를 지어내는 등 한계도 있었지만, 공격자 한 명이 다룰 수 있는 표적의 수는 크게 늘었습니다[7].

구글 위협정보그룹은 실행 중에 AI 에게 질문해 행동을 바꾸는 악성코드를 실제 공격에서 확인했습니다 [9]. 국내에서도 북한 배후로 추정되는 조직이 챗 GPT 로 만든 가짜 군무원 신분증을 미끼로 썼습니다 (2025 년 7 월) [10]. AI 를 쓰면 예전에는 손이 많이 가서 지나치던 작은 입구까지 한꺼번에 두드릴 수 있습니다. **수가 많고 곳곳에 흩어진 설문·신청서가 바로 그런 입구입니다.**

14 개 해킹 침투경로 한눈에

국내 발생 | 해외 발생 | 발생 가능성 높음

원 안의 숫자 = 해킹 침투경로 번호

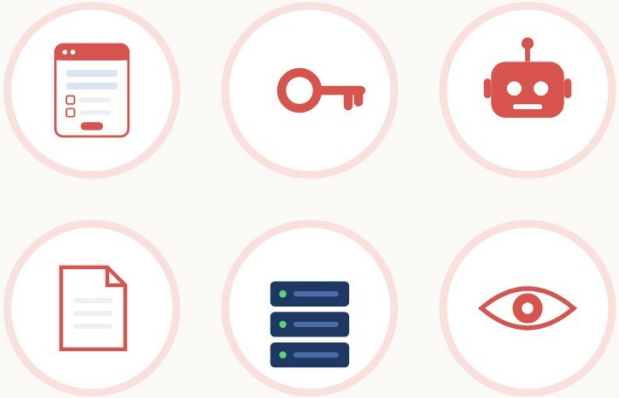


번호	해킹 침투경로	표시	가장 중요한 대응
1	설정 실수로 남의 응답이 보임	국내 발생	공개 범위 관리자 통제
2	폼 주인 계정 탈취 → 응답 통째 유출	국내 발생	기관 계정 + 피싱에 강한 인증
3	진짜 공식 폼이 가짜로 바뀜	발생 가능성 높음	수정 이력·2 인 확인
4	기관 사칭 가짜 신청서	해외 발생	기관 고유 주소 공지
5	응답 속 숨은 명령이 AI 비서 조종	발생 가능성 높음	외부 응답 분리 분석
6	첨부파일 → PC 감염 → 내부 서버	발생 가능성 높음	파일 격리 검사·원격접속 2 차 인증
7	유출 명단 → AI 맞춤 피싱	발생 가능성 높음	최소 수집·즉시 파기
8	외주업체 PC·계정 탈취	국내 발생	기관 계약 계정·2 단계 인증
9	끝난 사업 자료가 외주업체에 남음	국내 발생	파기 증빙·현장 확인
10	외주업체의 외부 사이트 업로드	국내 발생	외부 업로드 금지 계약
11	납품 파일·연동 앱으로 침투	발생 가능성 높음	서비스 안 열람·앱 승인 제한
12	외주 원격접속 → 원청 내부망	국내 발생	2 차 인증·IP 제한
13	SaaS 한 곳 → 고객사 전체	국내 발생	데이터 분리·파기 기준 확인
14	계정 거래·전화 사칭 연동 앱	국내·해외 발생	앱 승인 관리자 한정

Part 2.

기관이 직접 폼을 쓸 때

해킹 침투경로 1~7 · 담당자 개인 계정에 쌓이는 국민의 응답



담당자가 구글폼·네이버폼 같은 무료 외부 폼으로 설문·신청을 받는 경우입니다. 응답은 기관이 아니라 **담당자 개인 계정**에 쌓입니다.

해킹 침투경로 1 설정 하나 잘못으로 남의 응답이 보입니다 국내 발생

해킹 침투경로 1 · 국내 발생

적용: 공공기관 · 민간기업



AI가 바꾸는 것
공개된 폼 주소를 자동 프로그램이 대량으로 열어 보며, 사람보다 훨씬 빨리 설정 실수를 찾아낼 수 있습니다.

폼을 만들 때 '결과 보기'나 공유 범위를 잘못 설정하면, 응답을 마친 사람이 다른 사람의 응답까지 볼 수 있습니다. 해킹이 아니어도 유출입니다.

실제로 있었던 일

- 개인정보위는 2021~2025 년 외부 설문도구의 응답 노출로 **8 건의 과태료**를 의결했습니다. 음악방송 방청객 모집 폼은 약 33 분 동안 2,716 명, 크리에이터 가입 신청 폼은 11 일 동안 주민등록번호·계좌번호를 노출했습니다[11].
- '구글 서버 오류'라는 주장은 받아들여지지 않았습니다. 처분은 **폼을 만든 기관·기업**이 받았습니다[11].
- 공공기관 설문 149 건 중 98.7%는 안전조치 안내가 미흡했습니다[1].

이렇게 막습니다

- 공개 범위를 기관 관리자가 한꺼번에 통제하는 도구 쓰기
- 게시 전 '다른 계정으로 응답해 보기'로 노출 점검
- 주민등록번호·건강정보는 폼으로 받지 않기

해킹 침투경로 2 폼 주인 계정이 털리면 응답이 통째로 넘어갑니다 국내 발생(계정 침해)

해킹 침투경로 2 · 국내 발생(계정 침해)

적용: 공공기관 · 민간기업



AI가 바꾸는 것
털린 계정 수만 개 중에서 '공공기관 담당자 계정'만 자동으로 골라내고, 사람마다 맞춘 피싱 메일로 계정을 더 쉽게 훔칩니다.

폼과 응답, 첨부파일은 폼을 만든 사람의 계정에 쌓입니다. 그 계정이 털리면 그동안 받은 응답이 한꺼번에 넘어가고, 기관에는 아무 기록도 남지 않습니다.

실제로 있었던 일

- 2026 년 10 월, 6 개 지역 학교의 교육용 구글 계정 **11 만 2,890 개**에서 비정상 로그인과 비밀번호 무단 변경이 확인됐습니다. 대전에서는 하룻밤에 7 만여 개가 바뀌었고, 졸업생·퇴직자 계정을 정리하는 규정도 없었습니다[2][12]. 다만 보도로 확인된 것은 계정 침해까지이고, 폼 응답이 통째로 빠져나갔는지는 확인되지 않았습니다.
- 이 학교 계정들은 국정원 지침이 '보안인증 서비스 의무'의 예외로 둔 **'교육현장'**에서 쓰이던 것입니다. 예외 영역일수록 최소한의 계정 보안 기준이 필요합니다[13].
- 청와대 국민사서함은 관리자 1 명의 **개인 구글 계정**으로 3 만 8,741 건을 받았고, 내려받기·공유 이력은 "파기해 확인할 수 없다"고 답했습니다[14].
- 북한 배후 조직 김수키는 국세청 통지서로 위장한 메일로 네이버 가짜 로그인 화면을 띄워 계정을 노렸습니다(2025 년 2 월)[15].

이렇게 막습니다

- 개인 계정 대신 기관이 소유·관리하는 계정으로 운영
- 보안키·패스키처럼 피싱에 강한 인증 사용(보안키만 쓴 사용자 중 표적 피싱 피해자 0 명 [8])
- 로그인·내려받기 기록이 기관에 남는 도구 사용
- 인사이동·퇴직 때 권한 즉시 회수

해킹 침투경로 3 진짜 공식 폼이 '가짜'로 바뀝니다 발생 가능성 높음

해킹 침투경로 3 | ⚠ 발생 가능성 높음 | 공개 사례는 아직 없음 | 적용: 공공기관 · 민간기업



AI가 바꾸는 것
기관 말투와 형식을 흉내 낸 문항·안내문을 몇 분 만에 만들어,
바뀐 부분을 알아채기 더 어려워집니다.

계정을 빼앗은 공격자는 응답을 빼 가는 데 그치지 않고, 게시 중인 진짜 폼의 문항과 안내문을 몰래 바꿀 수 있습니다. 국민은 기관 홈페이지의 진짜 링크로 들어오기 때문에 의심하기 어렵습니다.

왜 가능성이 높은가

- **재료가 있습니다:** 폼 주인 계정 탈취는 국내에서 대규모로 일어났습니다(침투경로 2).
- **구조가 그렇습니다:** 폼 주인은 언제든 문항·안내문·완료 화면의 문구와 링크를 바꿀 수 있고, 바뀐 내용은 같은 주소로 바로 공개됩니다.
- **기술이 있습니다:** AI로 기관 말투와 화면을 흉내 내는 일은 이미 쉬워졌습니다[16].
- 공개된 피해 사례는 아직 없습니다.

이렇게 막습니다

- 폼 수정 이력과 알림이 기관에 남는 도구 사용
- 게시 중인 폼의 수정은 두 사람이 확인
- "폼에서 비밀번호·인증번호·계좌 비밀번호를 묻지 않습니다" 라고 미리 공지

해킹 침투경로 4 기관을 사칭한 가짜 신청서가 국민을 속입니다 해외 발생

해킹 침투경로 4 | 해외 발생

적용: 공공기관 · 민간기업 · 국민



AI가 바꾸는 것

생성형 AI로 진짜와 똑같은 화면과 문구를 몇 분 만에, 수백 개씩 만들 수 있습니다.
해외에서는 문장 몇 줄로 실제 로그인 화면을 복제한 사례가 확인됐습니다.

공격자가 무료 폼으로 기관 이름과 로고를 넣은 가짜 신청서를 만들어 문자·메일로 퍼뜨립니다. 주소가 대형 포털이라 보안 필터와 사람의 눈을 모두 통과하기 쉽습니다.

실제로 있었던 일

- 보안기업 Zimperium 은 미국 국세청(IRS)·은행·통신사 등 25 곳 이상을 사칭해 비밀번호를 훔치던 **구글폼 265 개**를 찾아냈습니다. google.com 주소라 평판 기반 탐지를 피했고, 피싱 목록에 오른 뒤에도 몇 달 동안 살아 있었습니다[17].
- 카스퍼스키는 구글폼 알림 메일이 구글 서버에서 발송돼 스팸 필터를 통과하기 쉽다는 점을 사기범이 악용했다고 분석했습니다(2025 년 7 월)[18].
- Okta 는 공격자가 생성형 AI 웹 제작 도구로 실제 로그인 화면을 문장 몇 줄만으로 복제한 사례를 확인했습니다(2025 년 7 월)[16].

이렇게 막습니다

- 기관 고유 주소(OO.go.kr 등)에서 신청을 받고 "공식 신청은 이 주소뿐" 이라고 공지
- 홈페이지 공지에 신청 링크를 함께 올려 국민이 대조할 수 있게
- 사칭 폼을 발견하면 서비스 사업자에 신고하고 홈페이지에 경고

해킹 침투경로 5 응답 속에 숨긴 명령이 AI 비서를 조종합니다 발생 가능성 높음

해킹 침투경로 5 ⚠ 발생 가능성 높음 같은 원리의 취약점이 해외 실제 서비스에서 확인 적용: 공공기관 · 민간기업



AI가 바꾸는 것
AI 비서가 있어야만 생기는 새로운 문입니다. 공격자는 계정을 훔칠 필요 없이 '응답' 하나만 제출하면 됩니다.

공격자가 응답자로 위장해, 사람 눈에는 평범해 보이는 'AI 용 명령'을 응답란에 숨겨 제출합니다. 담당자가 AI 비서에게 응답 정리를 맡기는 순간 그 명령이 실행될 수 있습니다.

왜 미리 막아야 하나

- **EchoLeak(2025):** 조작된 메일 한 통으로 Microsoft 365 Copilot 의 자료가 사용자 클릭 없이 외부로 새어 나갈 수 있었습니다[19].
- **GeminiJack(2025 년 12 월 공개):** 공유 문서·일정 초대에 숨긴 명령으로 Gemini Enterprise 가 메일·문서를 외부로 보낼 수 있었고, 구글은 구조를 바꿔 조치했습니다[20].
- 구글은 2026 년 4 월 이 위협이 "한 번 해결하고 끝나는 문제가 아니다"라고 밝혔습니다[21].
- 두 사례 모두 실제 서비스에서 확인되어 수정된 **취약점**이며, 실제 피해가 확인된 것은 아닙니다. 폼 응답을 통한 공개 사례도 아직 없지만, 폼 응답도 메일·공유 문서처럼 **누구나 써넣을 수 있는 외부 입력**입니다.

이렇게 막습니다

- 외부 응답은 메일·문서 접근 권한이 없는 별도 공간에서 AI 로 분석
- AI 결과 속 외부 링크·이미지가 자동으로 열리지 않게 설정
- AI 가 낸 결론은 사람이 최종 확인

해킹 침투경로 6 첨부파일 하나가 내부 서버까지 이어집니다 발생 가능성 높음

해킹 침투경로 6 | ⚠ 발생 가능성 높음 | 각 단계는 국내에서 이미 발생 | 적용: 공공기관 · 민간기업



AI가 바꾸는 것
AI를 품은 악성코드가 감염 PC에서 중요한 파일과 인증정보를 스스로 찾고,
AI 에이전트가 정찰·침투 작업의 80~90%를 대신한 사례가 해외에서 확인됐습니다.

공모전·증빙 접수 폼으로 업무 문서처럼 보이는 파일이 들어옵니다. 담당자가 그 파일을 열면 PC 가 감염되고, PC 에 저장된 인증정보로 내부 서버까지 갈 수 있습니다. **폼에서 시작해 내부 서버까지 이어진 공개 사례는 아직 없지만, 중간 단계는 국내에서 이미 모두 일어났습니다.**

단계마다 이미 일어난 일

- **PC 감염:** 금융 문서로 위장한 바로가기 파일이 정찰 뒤 원격 조종 도구를 설치하고, 명령과 자료 유출에 GitHub·Dropbox 같은 정상 서비스를 이용했습니다(2026 년 9 월)[22].
- **인증정보 → 내부 서버:** 해커가 공무원 인증서와 비밀번호를 손에 넣어 2022 년 9 월부터 2025 년 7 월까지 원격접속시스템을 통과해 온나라시스템 자료를 열람했습니다. 국정원은 정상 경로로 은밀히 진행되는 해킹은 기존 관제로 잡기 어렵다고 밝혔습니다[23].
- **AI 의 가세(해외):** AI 를 품은 악성코드가 감염 PC 에서 비밀정보를 찾는 사례가 확인됐습니다[9].

이렇게 막습니다

- 파일 업로드는 꼭 필요할 때만, 형식·크기 제한
- 받은 파일은 내려받지 말고 격리된 환경에서 검사·열람
- 원격접속 2 차 인증, 접속 이상 징후 상시 감시
- 업무 PC 에서 개인 계정 사용 금지

핵심 입장

폼에서 시작해 내부 서버까지 장악된 공개 사례는 아직 없지만, AI 해킹 기술의 발전을 고려할 때 충분히 발생 가능하며, 선제적 예방이 반드시 필요합니다.

해킹 침투경로 7 새어 나간 명단이 AI 맞춤 피싱의 재료가 됩니다 발생 가능성 높음

해킹 침투경로 7 ⚠ 발생 가능성 높음 재료(유출 명단)와 기술(AI 피싱)은 모두 국내에서 확인 적용: 공공기관 · 민간기업



AI가 바꾸는 것
손으로 한 사람씩 쓰던 '표적 피싱'을 수만 명에게 동시에,
한 사람 한 사람에게 맞춰 보낼 수 있습니다.

교육·행사 신청서에는 공직자의 이름·소속·직급·연락처가 한곳에 모입니다. 이 명단이 새면 AI 가 사람마다 다른 맞춤 피싱 메일을 대량으로 만드는 재료가 됩니다.

왜 가능성이 높은가: 재료와 기술이 모두 국내에 있습니다

- **재료:** 권익위 교육 사이트에서 공직자 **10 만 4,139 명**의 이름·생년월일·소속·직급·연락처가 유출됐습니다(2026 년 9 월)[3].
- **기술:** 김수키는 챗 GPT 로 만든 딥페이크 군무원 신분증 이미지로 군 관계 기관을 노렸습니다. 국내에서 생성형 AI 딥페이크가 공격에 쓰인 첫 확인 사례입니다(2025 년 7 월)[10].
- **경고:** 더존비즈온 사고 뒤 보안 전문가들은 유출된 기업·임직원·가족 정보로 더 정교한 2 차 표적 공격이 일어날 수 있다고 경고했습니다[4].

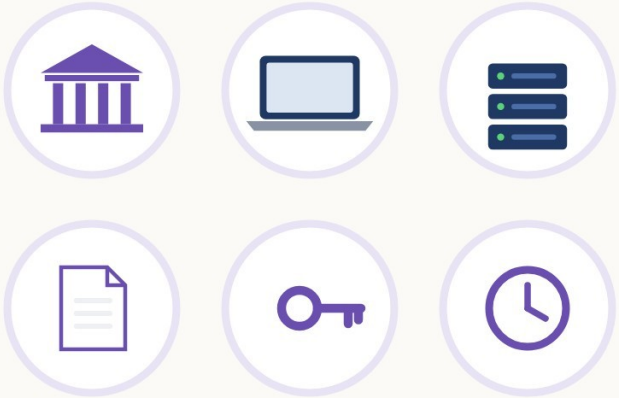
이렇게 막습니다

- 꼭 필요한 항목만 받기(직급·생년월일이 정말 필요한지 확인)
- 목적이 끝나면 즉시 파기하고 기록 남기기
- 공직자 대상 신청은 클라우드 보안인증 도구로

Part 3.

외주를 맡길 때

해킹 침투경로 8~12 · 기관이 볼 수 없는 업체의 계정과 서버



"폼은 업체가 만들었으니 우리는 안전하다" 는 생각은 틀렸습니다. 국민의 정보는 기관이 볼 수 없는 **외주업체의 계정과 서버**에 남고, 책임은 여전히 기관에 있습니다. 개인정보보호위원회도 외부 설문도구를 쓰더라도 안전조치 책임은 이용기관에 있다고 밝혔습니다[24].

해킹 침투경로 8 | **외주업체 PC·계정 하나로 여러 기관 자료가 털립니다** | **국내 발생**



외주업체 직원의 PC 나 관리자 계정 하나가 털리면, 그 업체가 맡은 여러 기관·기업의 자료가 한꺼번에 위험해집니다.

실제로 있었던 일

- 콜센터·텔레마케팅 아웃소싱 업체 KS 한국고용정보는 2025 년 4 월 해커에게 **관리자 계정**을 빼앗겼습니다. 상담사·직원·입사 지원자 4 만 875 명의 주민등록번호·계좌번호 등과 등본·가족관계증명서가 담긴 인사서류 5 만 건이 유출됐고, 해커는 다크웹 판매를 시도했습니다. 아이디·비밀번호만으로 외부에서 서버에 접속할 수 있었고, 과징금 35 억 3,700 만 원이 부과됐습니다(2026 년 4 월)[25].
- 해외에서도 2024 년 스노우플레이크 고객사 사건의 최초 감염이 계약자 PC 였고, 2 단계 인증이 없는 계정이 쓰였습니다. 약 165 개 조직이 통지를 받았습니다[26].

이렇게 막습니다

- 외주업체도 기관이 계약한 계정을 쓰고 2 단계 인증 의무화
- 접속 IP 제한, 계약이 끝나면 즉시 계정 회수
- 외주 PC 보안 점검을 계약 조건에

해킹 침투경로 9 끝난 사업의 자료가 외주업체에 남아 있다가 털립니다 국내 발생

해킹 침투경로 9 · 국내 발생

적용: 외주업체 · SaaS → 공공기관 · 민간기업



AI가 바꾸는 것
인터넷에 남아 있는 옛 시스템을 자동 탐색으로 더 빨리 찾아냅니다.

사업이 끝나면 업체는 '파기 완료'를 보고합니다. 그러나 옛 서버나 백업에 자료가 남아 있으면, 아무도 관리하지 않는 그 서버가 공격의 표적이 됩니다.

실제로 있었던 일

- 권익위 교육 사이트의 수탁사는 2025 년 서버를 바꾸면서 옛 서버의 회원정보를 지우지 않았고, 1 년 반 동안 파기 항목을 '양호'로 보고했습니다. 권익위의 점검은 업체 자체 점검에만 의존했고, 옛 서버가 해킹돼 **공직자 10 만 4,139 명**의 정보가 유출됐습니다(2026 년 9 월)[3].
- 같은 업체(맑은소프트)의 고객사 22 곳에서 약 237 만 건의 유출이 신고됐습니다[5].
- 더존비즈온 사고에서 서울시육아종합지원센터는 서비스를 끝낸 뒤에도 데이터가 지워지지 않아 유출 가능성을 알렸습니다 (2026 년 11 월)[27].

이렇게 막습니다

- 종료·이관 때 파기 증빙을 받고 직접 확인
- 처음부터 기관이 계약한 서비스 안에서 수집해 자료가 업체에 남지 않게

해킹 침투경로 10 외주업체가 원본 파일을 외부 사이트에 올립니다 국내 발생



AI가 바꾸는 것
공개 저장소·검사 사이트에 올라온 파일을 자동으로 수집·분류해 쓸 만한 자료를 골라낼 수 있습니다(예상).

외주업체가 파일 검사·변환·공유를 위해 검증되지 않은 외부 웹사이트에 원본을 올리면, 그 사이트의 공개 정책에 따라 누구나 볼 수 있게 될 수 있습니다.

실제로 있었던 일

- 대통령 부부를 포함한 공군 1호기 탑승자 **168 명의 명단**이 약 5 개월 동안 외부 사이트에 노출됐습니다. 정부는 외교부의 보안 용역업체가 악성코드 검사 사이트에 파일의 고유 식별값 대신 원본 파일을 올린 정황을 조사하고 있습니다(2026 년 11 월)[6] [28].
- 보안을 맡은 업체조차 외부 도구를 쓰는 순간 정보가 기관 밖으로 나갈 수 있음을 보여 줍니다.

이렇게 막습니다

- 계약서에 '외부 웹서비스 원본 업로드 금지' 명시
- 업무 PC 에서 외부 업로드를 막는 유출 방지 장치
- 악성코드 검사는 기관이 승인한 도구로만

해킹 침투경로 11 납품 파일과 '연동 앱' 승인으로 기관 안까지 들어옵니다

발생 가능성 높음

해킹 침투경로 11 | ⚠ 발생 가능성 높음 | 연동 앱 수법은 해외에서 발생 | 적용: 외주업체 → 공공기관 · 민간기업



AI가 바꾸는 것
업무 문서와 똑같은 미끼 파일과 그럴듯한 승인 요청을 상대에 맞춰 만들어 냅니다.

외주업체가 납품한 결과 파일, 또는 "자동 연동이 필요하다"며 요청한 앱 승인이 기관 안으로 들어오는 통로가 될 수 있습니다.

왜 가능성이 높은가

- **연동 앱(해외 발생):** IT 지원팀을 사칭한 전화로 직원이 악성 연동 앱을 승인하게 만든 뒤 고객관리(CRM) 자료를 대량으로 빼낸 사례가 확인됐습니다(2025 년)[29].
- **미끼 파일(국내 발생):** 업무 문서로 위장한 악성 파일 공격은 국내에서 꾸준히 확인됩니다(2026 년 9 월)[22].
- 외주 납품 파일이 출발점인 공개 사례는 아직 없습니다.

이렇게 막습니다

- 파일로 주고받지 말고 기관 서비스 안에서 결과 열람
- 받은 파일은 격리 검사 뒤 열기
- 연동 앱 승인은 관리자만 할 수 있게 설정

해킹 침투경로 12 외주업체의 원격접속 계정으로 원청 내부망에 들어옵니다

국내 발생

해킹 침투경로 12 · 국내 발생

적용: 유지보수 외주업체 → 공공기관 · 민간기업



AI가 바꾸는 것
내부 정찰과 '권한 높은 계정' 찾기를 AI가 자동으로 수행합니다.

외주 유지보수 업체 직원의 원격접속 계정이 털리면, 공격자는 정상 직원처럼 원청의 서버에 들어올 수 있습니다.

실제로 있었던 일

- 북한 해킹조직은 방산 협력업체 서버를 유지보수하는 업체 직원의 계정을 빼앗아 악성코드를 심고 자료를 빼냈습니다. 관리가 소홀한 망연계 시스템을 거쳐 내부망에 들어왔고, **방산업체 10여 곳**이 피해를 입었습니다(2024 년 4 월 경찰 발표)[30].
- 더존비즈온은 직원의 VPN(원격접속) 계정으로 무단 접속을 당했습니다(2026 년 10 월)[31].

이렇게 막습니다

- 원격접속에 2 차 인증과 접속 IP 제한
- 필요한 시스템에만, 필요한 기간만 권한 부여
- 접속 기록 상시 점검

업무 특성에 따른 우선 점검 대상: 어디부터 살펴야 하나

AI 해킹은 **값나가는 자료가 많고, 지키는 힘이 약한 곳**부터 노립니다. 아래 지도는 국내 외주 업종을 '가진 정보의 가치'와 '취약성'으로 나눠, 먼저 살펴야 할 곳을 표시한 것입니다. 업종별 사고율을 비교한 객관적 순위가 아니라, 우선 점검 대상을 고르기 위한 제안입니다.



평가 기준 — 가치: 정보의 규모·민감도(주민번호·가족·급여 등)·내부망 접근 여부 / 취약성: 무료 도구 의존, 서류 업로드 비중, 자료 보관·파기 관리, 보안 인력. 공개 사례와 업무 특성을 바탕으로 한 정성 평가입니다.

업종별 자세히 보기

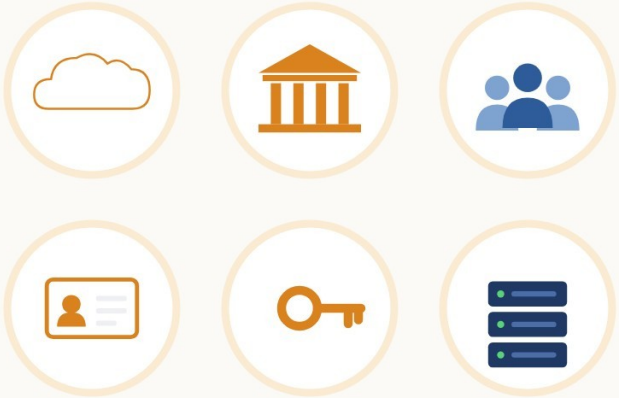
업종	가진 정보	약한 고리	국내 사례	점검 순위
채용 대행·인력 아웃소싱	주민번호, 학력·경력, 사진, 가족관계 서류	서류 업로드가 많음, 근거 없는 주민번호 수집	인사서류 5 만 건 유출[25], 지자체 채용 외주 페이지 노출[32]	1 순위
세무·회계 ERP(SaaS)	임직원·가족 주민번호, 급여 계좌, 거래처	수많은 고객 자료가 한곳에	더존비즈온[31], 자비스[33]	1 순위
IT 유지보수·보안 용역	내부망 접근 권한 그 자체	원격접속 계정, 외부 도구 사용	방산 협력업체[30], 1 호기 명단[6]	1 순위
리서치·여론조사	대규모 국민 응답, 연락처, 성향	무료 도구·웹하드 의존	15 곳 중 14 곳 법 위반(2018 점검)[34], 북한의 여론조사 기관 공격 시도[35]	1 순위
교육·연수 위탁	공직자 명단(이름·소속·직급·연락처)	옛 서버 방치, 자체 점검 의존	공직자 10 만여 명 유출[3]	1 순위
홈페이지 제작·운영	신청자 정보	취약점 관리 부족	지자체 산하 홈페이지 노출 위험[32]	2 순위
행사·이벤트 대행	이름·연락처·주소, 경품용 주민번호	단기 사업, 무료 폼 의존	방청객 모집 폼 2,716 명 노출 등[11]	2 순위
마케팅·홍보 대행	대량 연락처, 소비 성향	무료 폼 의존, 재위탁	공개 사례 확인 못 함	2 순위
경영·조직 컨설팅	임직원 설문·인터뷰, 내부 자료	개인 계정 공유 드라이브	공개 사례 확인 못 함	3 순위

1 순위 업종에 일을 맡기는 기관·기업은 외주 계약서에 ‘클라우드 보안인증 도구 사용’과 ‘파기 확인’을 가장 먼저 넣어야 합니다(7 부 참고).

Part 4.

민간 기업과 플랫폼

해킹 침투경로 13~14 · 한 곳이 뚫리면 모두가 피해를 보는 구조



민간 기업도 같은 문을 엽니다. **침투경로 1·2·4·5 는 기업의 이벤트·가입 신청 폼에서도 그대로 일어나며**, 개인정보위 과태료 의결 8 건 가운데 다수가 민간 기업이었습니다[11]. 여기에 민간에서 특히 피해가 큰 두 경로가 더해집니다.

해킹 침투경로 13 | **SaaS 플랫폼 한 곳이 뚫리면 고객사 전체가 피해를 봅니다** | **국내 발생**



수많은 기업·기관이 같은 클라우드 소프트웨어(SaaS)에 자료를 맡깁니다. 그 플랫폼 한 곳이 뚫리면 피해는 고객사 전체로 번집니다.

실제로 있었던 일

- **더존비즈온(2026 년 10 월):** 직원 VPN 계정으로 무단 접속을 당해 ERP '스마트 A10' 고객사의 이름·주민등록번호·계좌번호 등이 유출됐을 가능성이 있고, 백업 서비스 서버의 취약점으로 암호화된 데이터도 반출됐습니다. 정부는 '중대한 사고'로 보고 민관합동조사단을 꾸렸습니다[31][4].
- 스마트 A10 은 **11 만 곳 이상의 기업**이 쓰고(회사 측), 급여 계좌와 연말정산용 가족 주민번호, 거래처 정보까지 담길 수 있습니다[4]. 유출 가능성을 알린 고객사에는 국립박물관단지·춘천문화재단 같은 공공 부문 기관도 있습니다[27]. 7 월에는 온라인 고객센터의 파일 업로드 취약점으로 별도 유출도 있었습니다[36].
- 맑은소프트 고객사 22 곳 약 237 만 건(2026 년 9 월)[5], AI 세무·경리 서비스 자비스의 급여·카드·공동인증서 정보 유출 정황(2026 년 11 월)[33].

이렇게 막습니다

- 도입 전 확인: 클라우드 보안인증 여부, 고객사별 데이터 분리, 보관·파기 기준, 사고 통지 의무
- 계약이 끝나면 데이터 삭제 증빙 받기
- 플랫폼에는 꼭 필요한 정보만 맡기기

해킹 침투경로 14 계정 거래와 ‘전화 사칭’으로 기업 자료가 대량 반출됩니다

국내 발생

해킹 침투경로 14 · 국내·해외 발생

적용: 민간기업 · 공공기관



AI가 바꾸는 것
AI가 상대에 맞춘 대본과 가짜 화면을 만들어,
전화·메일 사칭이 더 그럴듯해집니다(예상).

피싱 메일과 ‘IT 지원팀’을 사칭한 전화로 계정을 빼앗거나 악성 연동 앱 승인을 받아 내면, 메일·클라우드·고객관리 자료가 한꺼번에 빠져나갑니다.

실제로 있었던 일

- **국내:** 네이버 인기 블로그 운영자에게 ‘해외 로그인’ 경고를 사칭한 메일을 보내 약 150 개 계정을 해킹하고, 1 개당 1,000 만~1,500 만 원에 판매한 일당이 검거됐습니다(2022 년)[37].
- **해외:** 구글 위협정보그룹은 IT 지원팀 사칭 전화로 연동 앱 승인을 받아 세일즈포스 고객 자료를 대량으로 빼내고 몇 달 뒤 협박한 조직(UNC6040)을 추적했습니다. 플랫폼의 취약점이 아니라 사람을 속이는 방식이었습니다(2025 년)[29].

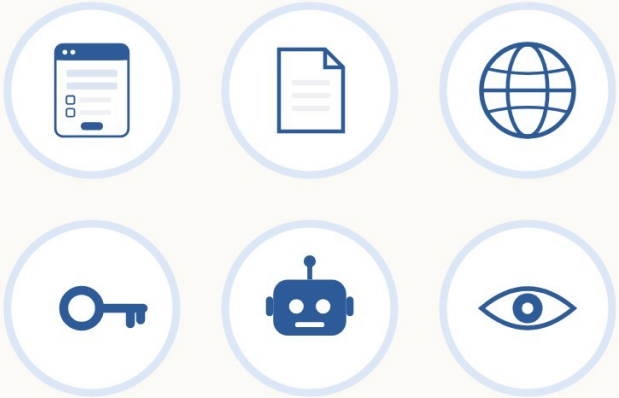
이렇게 막습니다

- 연동 앱 승인 권한은 관리자만
- IT 지원 요청 전화는 대표번호로 되걸어 확인
- 피싱에 강한 인증(보안키·패스키) 사용

Part 5.

기술적 근거

보안인증 없는 외부 폼이 해킹 통로가 되는 6 가지 이유



구글폼·네이버폼 같은 서비스 자체가 허술하다는 뜻이 아닙니다. 구글은 모든 폼 아래에 '비밀번호를 제출하지 마세요' 라는 경고를 자동으로 붙이고, 민감한 정보를 요구하는 폼을 탐지·차단한다고 밝혔습니다[17]. **문제는 서비스의 보안 수준이 아니라, 이 도구가 기관의 보안 울타리 밖에 있다는 구조**입니다.



6 가지 이유, 자세히 보기

이유	기술적으로 무슨 뜻인가	근거
1. 누구나 들어옵니다	로그인 없이(또는 아무 계정으로) 누구나 써넣을 수 있게 만든 도구입니다. 기관 시스템 대부분은 직원만 쓰지만, 폼은 모르는 사람의 입력을 일부러 받습니다.	구조적 특성
2. 파일이 들어옵니다	파일 업로드를 켜면 응답자가 올린 파일이 담당자 저장공간에 쌓이고 담당자 PC 에서 열립니다. 허용 형식(문서·PDF·이미지)을 정해도 그 안에 악성 기능을 숨긴 파일은 만들 수 있고, 기관의 백신·격리 검사를 거치지 않습니다.	업무 문서 위장 악성 파일[22] · 업로드 기능 취약점으로 서버가 뚫린 국내 사례: 모두투어(웹셸 설치 뒤 306 만 건 유출, 과징금 7 억 4,700 만 원)[38], 더존 고객센터[36], KS 한국고용정보(파일 경로 미검증)[25]
3. 믿을 만한 주소가 방패	폼 주소는 대형 포털 주소이고 정상 보안 인증서를 갖고 있습니다. 많은 보안 장비가 이런 주소를 예외로 두기 때문에, 악용되면 필터를 그대로 통과합니다. 정상 클라우드 서비스가 해킹 명령을 주고받는 통로로 쓰이기도 합니다.	사칭 구글폼 265 개[17] · 구글폼 알림 메일 악용[18] · 구글 시트·드라이브를 명령 통로로 쓴 해킹 도구[39] · GitHub·Dropbox 악용[22]
4. 폼 하나 = 계정 전체	폼은 담당자 계정의 메일·드라이브·저장된 비밀번호·연결된 앱과 한 몸입니다. 정보탈취 악성코드는 로그인 상태 정보(세션)를 훔쳐 비밀번호와 2 단계 인증 없이도 접속하고, 일부는 만료된 구글 로그인을 되살리기도 했습니다.	교육용 구글 계정 11 만 개[2] · 세션 되살리기 악성코드[40] · 2 단계 인증 뒤 세션을 가로채는 피싱, 1 만여 조직 공격[41]
5. 응답이 곧 AI 입력	AI 비서가 응답 시트를 읽는 순간 응답 속 문장은 AI 에게 주는 입력이 됩니다. AI 비서가 같은 계정의 메일·문서에 접근할 수 있다면 피해는 응답을 넘어섭니다.	EchoLeak[19] · GeminiJack[20] · 구글 공식 입장[21]
6. 기관의 눈 밖	기관의 보안관제·접속기록 체계와 연결돼 있지 않습니다. 누가 언제 응답을 내려받았는지 기관이 알 수 없고, 사고가 나도 조사 협조를 요구할 계약이 없습니다. 자료가 해외에 저장될 수도 있습니다.	국민사서함 이력 확인 불가[14] · 국외이전 안내 미흡 66.4%[1] · '정상 경로' 해킹은 기존 관제로 잡기 어려움[23]

Part 6.

해법: 국가가 검증한 클라우드 도구

보안인증 도구는 어떻게 해킹을 막는가



클라우드 보안인증이란

클라우드 보안인증은 공공기관이 쓸 민간 클라우드 서비스를 **국가가 미리 점검해 '국민 정보를 맡겨도 된다' 고 확인해 주는 제도**입니다. 식품의 위생 인증처럼, 기관마다 서비스의 보안을 일일이 따지지 않아도 되도록 국가가 기준을 세우고 대신 확인합니다.

목적은 두 가지입니다. 공공기관도 민간 클라우드의 편리함을 누리게 하는 것, 그리고 그러면서도 **국민 정보가 국내에, 기관의 통제 아래 있고, 사고가 나면 국가가 조사할 수 있게** 하는 것입니다.

> **정식 명칭**
>
> 클라우드 보안인증(CSAP)은 과학기술정보통신부와 한국인터넷진흥원(KISA)이 운영합니다. 인증은 관리·물리·기술적 보호조치와 공공기관용 추가 보호조치 등 서비스 유형·등급에 따라 30~117 개 항목을 점검하고, 매년 사후 점검을 합니다[42][43]. 국가정보원은 공공기관이 쓸 수 있는 서비스를 「국가·공공기관 민간 클라우드 컴퓨팅서비스 도입 가능 목록」으로 공개합니다(2026 년 9 월 30 일 기준 219 건)[44].

걸어온 길



2016 년 첫 인증과 2019 년 간편등급, 2023 년 등급제·목록 공개[45] · 2026 년 등급별 이용 조건과 2027 년 일원화 계획[46]

제도는 계속 발전하고 있습니다. 정부는 2026 년 4 월 공공 클라우드 보안정책 개편 방안을 내놓았고, 국정원은 9 월 기밀·민감·공개 등급별 이용 조건을 공개했습니다. 2027 년 하반기부터는 인증과 검증으로 나뉘어 있던 절차를 국정원 보안검증으로 일원화할 예정입니다[46]. **이름과 절차가 바뀌어도 '국가가 검증한 클라우드만 쓴다' 는 원칙은 같습니다.**

무엇이 다른가

	보안인증 없는 무료 폼 담당자 개인 계정	클라우드 보안인증 도구 기관이 계약한 계정
계정 주인	✗ 담당자 개인 이동·퇴직 뒤 회수 어려움	✓ 기관 담당자가 바뀌면 기관이 회수
자료가 있는 곳	✗ 해외 저장 가능	✓ 시스템·데이터·백업·운영 인력 모두 국내
누가 점검하나	✗ 사업자 자체 기준	✓ 국가 인증 심사 + 매년 사후 점검
공공·민간 분리	✗ 일반 이용자와 같은 환경	✓ 공공기관용 영역 분리
기록·감시	✗ 기관이 볼 수 없음	✓ 보안관제 지원
사고가 나면	✗ 조사 협조 약속 없음	✓ 계약에 사고조사 협조 명시
파기 확인	✗ 담당자 개인 판단	✓ 계약으로 파기 확인

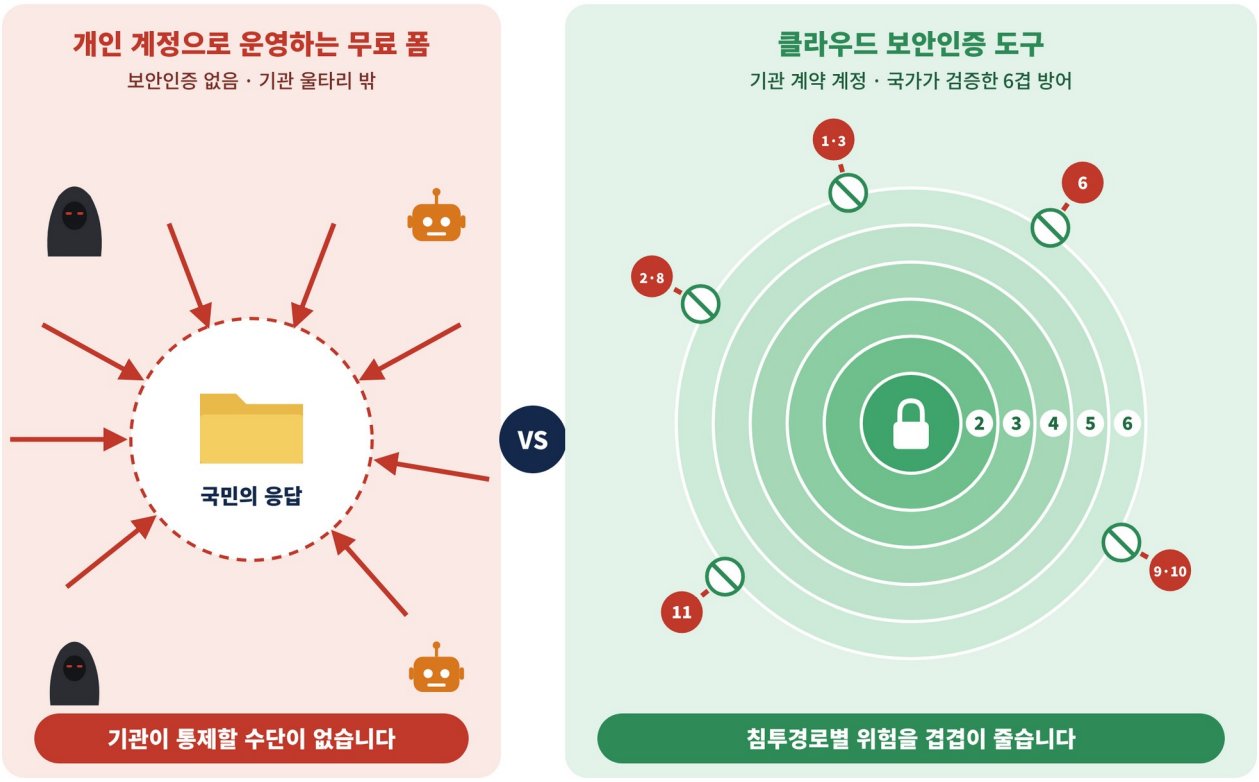
여기서 비교하는 대상은 실태조사에서 확인된 **'담당자 개인 계정으로 운영하는 무료 폼'** 입니다. 조직용 서비스에도 관리·보안 기능이 있을 수 있고, 인증 도구라고 해서 서비스의 기술이 반드시 더 뛰어나다는 뜻은 아닙니다. 차이는 **누가 계정을 소유하고, 자료가 어디에 있으며, 사고가 났을 때 기관이 무엇을 확인하고 요구할 수 있느냐**에 있습니다. 실제로 네이버도 공공기관용 업무 서비스는 별도 제품으로 인증을 받아 목록에 올라 있습니다 [44].

해킹 방어효과	해당 침투경로	이유와 조건
크게 줄어듭니다	1 · 2 · 3 · 6 · 7 · 8 · 9 · 13	결과 비공개, 모든 계정 2 단계 인증, 수정 기록·알림, 파일 백신 검사, 외주 계정·권한 관리, 파기 증빙, 플랫폼 권한 통제를 갖춘 경우
해킹경로가 차단됩니다	10 · 11	외주업체가 자료를 내려받지 않고 서비스 안에서 결과를 확인하면, 파일을 주고받는 업무상 경로 자체가 없어집니다(일부러 화면을 찍어 빼내는 일은 따로 관리해야 합니다)
일부 줄어듭니다	4 · 14	사칭·전화 사기처럼 사람을 속이는 공격은 도구 밖에서 일어납니다. 보안키·패스키를 쓰면 더 줄어듭니다
별도 대책이 필요합니다	5	기관의 AI 비서 사용 규칙이 필요합니다
설문 도구와 관계없습니다	12	기관의 원격접속(VPN) 관리 문제입니다

※ 연구진의 판단으로, 실제 기능 시험 결과는 아닙니다. 실제 효과는 제품의 기능과 기관의 운영에 따라 달라지므로 7 부의 확인 항목을 함께 보세요.

보안인증 도구는 이렇게 해킹을 막습니다

보안인증 도구는 국민의 응답을 **여섯 겹의 방어막**으로 감쌉니다. 무료 폼에서는 그대로 들어오던 공격이 방어막을 지날 때마다 줄어들거나 막힙니다. ③ 보관·분리, ⑤ 감시·대응, ⑥ 국가 검증은 인증으로 보장되고, ① 계정 통제, ② 공개·수정 통제, ④ 파일 처리는 제품마다 다르니 도입할 때 꼭 확인해야 합니다.



1 계정 통제	2 공개·수정 통제	3 보관·분리	4 파일 처리	5 감시·대응	6 국가 검증
2단계 인증·접근 제한 (도구 기능 확인)	공개 범위·수정 이력 (도구 기능 확인)	국내·공공 전용 영역 (CSAP 보장)	업로드 검사·백신 (도구 기능 확인)	보안관제·사고조사 협조 (CSAP 보장)	유형·등급별 심사·매년 점 (CSAP 보장)

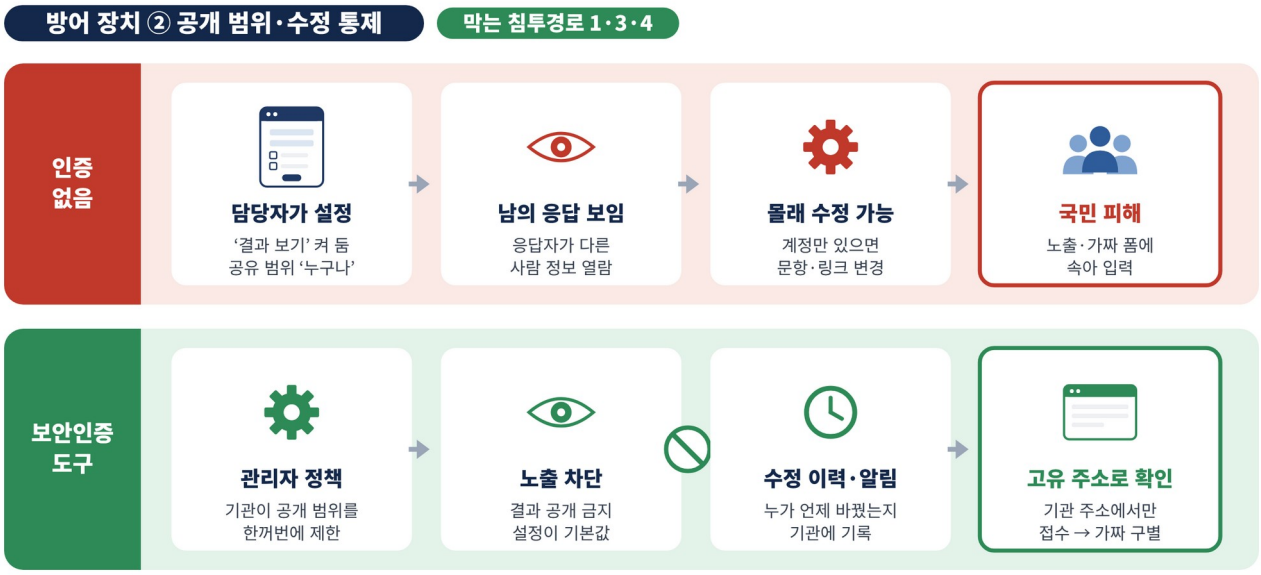
아래 그림들은 **같은 공격이 들어왔을 때** 인증 없는 폼과 보안인증 도구에서 각각 어떤 일이 벌어지는지 나란히 보여줍니다. 위 줄은 피해가 나는 과정, 아래 줄은 방어막이 공격을 끊는 지점입니다.

방어막 ① 계정 통제: 비밀번호가 새도 쉽게 못 들어옵니다



계정의 주인이 담당자 개인이 아니라 **기관**이기 때문에, 모든 계정에 2 단계 인증과 접속 제한을 한꺼번에 걸 수 있습니다. 수상한 접속이 보이면 관리자가 바로 권한을 회수합니다. 다만 2 단계 인증이 모든 계정에 적용됐는지는 도입할 때 확인해야 합니다. **관련 침투경로: 2 · 3 · 8 · 14**

방어막 ② 공개·수정 통제: 설정 실수와 바꿔치기를 막습니다



결과 공개는 기본으로 꺼져 있고, 기관 관리자만 바꿀 수 있습니다. 누가 언제 문항을 고쳤는지 모두 기록이 남아 몰래 바꿔치기하기 어렵습니다. **관련 침투경로: 1 · 3 · 4**

방어막 ③ 보관·분리: 자료가 국내 전용 공간에만 있습니다

방어 장치 ③ 자료 보관·파기 막는 침투경로 7·9·10



응답은 인증된 서비스 안, 그것도 국내의 공공 전용 공간에만 보관됩니다. 외주업체나 담당자 컴퓨터로 사본을 옮길 일이 줄고, 사업이 끝나면 서비스에서 한 번에 지울 수 있습니다. 파기 증빙 기능이 있는지는 도입할 때 확인하세요. **관련 침투경로: 7 · 9 · 10**

방어막 ④ 파일 처리: PC 감염 고리를 약하게 만듭니다

방어 장치 ④ 파일·첨부 처리 막는 침투경로 6·11



※ 저장소 파일 검사 적용 여부와 내려받기 제한 수칙을 함께 확인해야 효과가 납니다.

파일이 올라오는 순간 웹방화벽(WAF)과 서버 백신이 검사하고, 담당자는 내려받지 않고 서비스 안에서 확인합니다. 악성 파일이 기관 내부망으로 건너갈 다리가 크게 줄어듭니다. 저장된 파일까지 백신으로 검사하는지는 도입할 때 확인하세요. **관련 침투경로: 6 · 11**

방어막 ⑤ 감시·사고 대응: 조용한 침입을 찾아냅니다



보안관제를 지원하고 접속 기록을 남기기 때문에, 정상 직원인 척 들어온 침입자를 빨리 찾아낼 수 있습니다. 사고가 나면 계약에 따라 국가가 함께 조사합니다. **관련 침투경로: 6 · 13**

방어막 ⑥ 국가 검증: 국가가 미리, 그리고 매년 확인합니다



국가는 인증 기준에 해당하는 보호조치를 **서비스 유형·등급에 따라 30~117 개 항목으로 미리 심사**하고, 인증 뒤에도 해마다 다시 점검합니다. 다만 계정·공개 설정·파일 처리 같은 제품별 세부 기능은 기관이 도입할 때 직접 확인해야 합니다.

침투경로별 방어 지도

14 개 해킹 침투경로 하나하나에 어떤 방어막이 작동하는지, **얼마나 줄어드는지(해킹 방어효과) 정리했습니다. '별도 대책' 과 '도구 범위 밖' 경로는 7 부의 운영 수칙을 함께 지켜야 합니다.

	① 계정 통제 (도구 기능)	② 공개·수정 통제 (도구 기능)	③ 보관·분리 (CSAP 보장)	④ 파일 처리 (도구 기능)	⑤ 감시·대응 (CSAP 보장)	해킹 방어효과 (확인 항목을 갖춘 인증 도구)
1 설정 실수로 응답 노출	·	●	·	·	·	크게 줄어듦
2 폼 주인 계정 탈취	○	·	·	·	○	크게 줄어듦
3 공식 폼 바꿔치기	○	◌	·	·	○	크게 줄어듦
4 기관 사칭 가짜 폼	·	○	·	·	·	일부 줄어듦
5 숨은 명령으로 AI 비서 조종	·	·	·	·	·	별도 대책
6 첨부파일 → 내부 서버	·	·	·	○	○	크게 줄어듦
7 유출 명단 → AI 피싱	○	·	○	·	·	크게 줄어듦
8 외주업체 계정 탈취	○	◌	○	·	○	크게 줄어듦
9 끝난 사업 자료 잔존	·	◌	◌	·	·	크게 줄어듦
10 외부 사이트 업로드	·	◌	○	·	·	해킹경로 차단
11 납품 파일·연동 앱	·	◌	·	○	·	해킹경로 차단
12 외주 원격접속 → 내부망	·	·	·	·	·	도구 범위 밖
13 인증 SaaS 플랫폼 자체 침해	◌	·	○	·	○	크게 줄어듦
14 계정 거래·전화 사칭	○	·	·	·	○	일부 줄어듦

● 직접 막음 ○ 피해를 줄임 ◌ 도입 시 기능 확인 필요

연구진 판단 · 'CSAP 보장'은 인증 기준 항목, '도구 기능'은 제품별 확인 항목

※ 꼭 필요한 기능(계정 보호·공개 제한·파일 검사·외주 권한·파기 증빙)을 갖춘 인증 도구를 기준으로 한 연구진 판단입니다.

공공은 의무, 민간은 적극 도입

공공기관: 의무	민간 기업: 적극 도입 권장
• 국정원 「국가 사이버보안 기본지침」은 민간 클라우드를 쓸 때 **'도입 가능 목록'의 서비스를 쓰고**, 계약에 보안관제·사고조사 협조를 명시하도록 정하고 있습니다[13]. • 개인정보위는 외부 설문도구를 써도 최소 수집·공개 설정 금지·파기 등 **안전조치 책임이 폼을 만든 기관에** 있다고 밝혔습니다(2026 년 10 월)[24]. • 그런데도 137 개 기관이 개인정보를 받는 설문 149 건을 인증 없는 도구로 운영했고[1], 개인정보 보호를 담당하는 개인정보위의 위탁사업에서도 구글폼이 쓰였습니다[47]. • **예외:** 국·공립학교 등 '교육현장'은 이 의무에서 빠져 학교장 책임에 맡겨져 있습니다[13][48]. 그런데 2026 년 10 월 교육용 구글 계정 11 만여 개 침해가 바로 이 영역에서 일어났습니다. 예외를 두더라도 2 단계 인증, 졸업·퇴직자 계정 정리 같은 최소 기준은 꼭 필요합니다.	• 법적 의무는 없지만, 고객·임직원 개인정보를 받는 폼과 SaaS 는 **인증 도구를 먼저 고려**하는 것이 합리적입니다. • 사고의 대가가 큽니다: 모두투어 과징금 7 억 4,700 만 원[38], KS 한국고용정보 35 억 3,700 만 원[25]. • 인증 목록은 공공기관용이지만, 기업이 서비스를 고를 때 **'국가가 점검한 서비스' 목록**으로 그대로 활용할 수 있습니다.

인증도 만능은 아닙니다

- 인증은 **서비스 제공자의 보호조치**를 평가합니다. 담당자의 설정 실수, 계정 관리, 피싱 대응까지 보증하지는 않으므로 7 부의 운영 수칙과 함께 써야 합니다.
- AI 요약·분석 기능이 있는 서비스는 숨은 명령(침투경로 5)에 대한 대응을 따로 확인해야 합니다.
- 여러 고객사가 함께 쓰는 서비스는 인증 여부와 관계없이 고객사별 데이터 분리와 파기 기준을 계약 단계에서 확인해야 합니다(침투경로 13).
- 인증과 목록 등재는 특정 제품에 대한 정부의 추천이 아닙니다. 업무에 맞는 서비스를 목록 안에서 비교해 고르면 됩니다.

Part 7.

기관·기업이 할 일

대안 비교 · 실행 로드맵 · 외주 계약



세 가지 대안



* 자체 구축은 통제력이 가장 높지만 보안을 직접 책임져야 합니다. 모두투어와 더존 고객센터 사고는 모두 자체 웹사이트의 파일 업로드 기능에서 시작됐습니다[38][36].

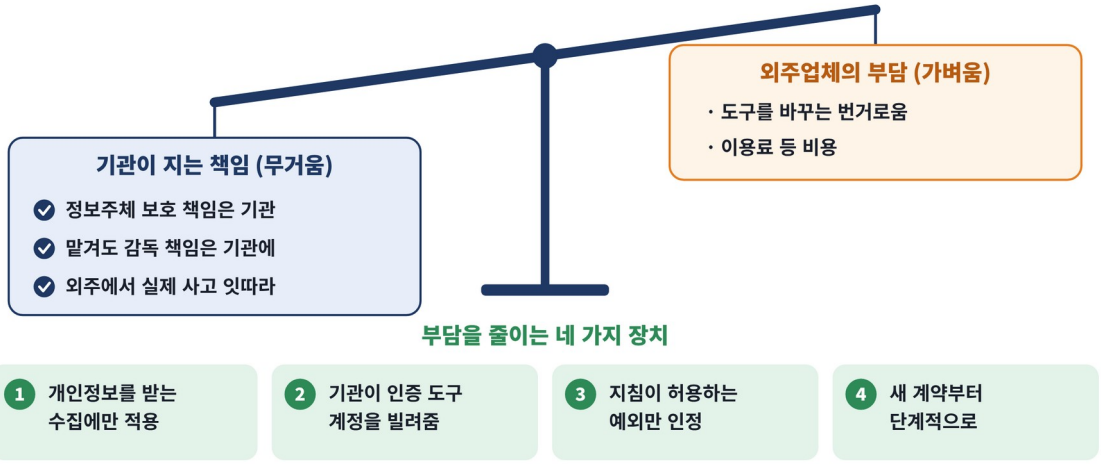
대부분의 기관·기업에는 **A(보안인증 클라우드 도구)가 가장 빠르고 현실적인 선택**입니다. 상위기관이 일괄 계약해 산하기관·학교에 나눠 주는 C 는 비용과 운영 부담을 가장 크게 줄입니다. 상시로 대규모 신청을 받고 보안 인력이 있는 기관은 B 를 함께 검토할 수 있습니다.

단계별 실행 로드맵

기술만 바꿔서는 막을 수 없습니다. 사람과 일하는 방식이 함께 바뀌어야 합니다.

시기	기술	인력·조직	업무 프로세스
단기 즉시~3 개월	• 개인정보를 받는 폼 전수 점검(도구·계정 주인·공개 설정·항목) • 주민번호·건강정보를 받는 폼 즉시 중단 • 운영 중인 계정에 2 단계 인증 • 보유기간 지난 응답·내려받은 파일 파기	• 수집 도구 책임자 지정(개인정보 보호책임자 산하) • 담당자 대상 '폼 보안 10 분 교육' (설정 실수·피싱)	• '새 폼 게시 전 점검표' 의무화 • 진행 중인 외주 사업의 수집 도구·계정 확인 공문
중기 3 개월~1 년	• 클라우드 보안인증 도구로 전환(대안 A·C) • 기관 계정·관리자 통제, 수정 이력 관리 • 파일은 격리 검사 환경에서 열람 • 보안키·패스키 도입	• 부서별 수집 담당자 지정과 권한 관리 • 인사이동 때 계정 이관 절차 • 외주 관리 담당자 지정	• 과업지시서에 '보안인증 도구 사용' 조건 반영 • 파기 증빙·현장 확인 절차 • AI 비서로 외부 응답을 분석할 때의 규칙
장기 1~3 년	• 상시 대규모 수집은 자체 구축·공동 플랫폼 검토(대안 B·C) • 원격접속·업무 PC 이상 징후 상시 감시 • AI 기능 탑재 도구의 숨은 명령 대응 확인	• AI 보안 교육 정례화 • 외주업체 보안 평가 체계	• 사이버보안 실태평가·개인정보 보호수준 평가에 '수집 도구' 항목 반영 • 가짜 폼·피싱 모의훈련 정례화

외주 계약: 강제인가, 당연한 조건인가



공공기관이 외주업체에게도 클라우드 보안인증 도구로 수집하라고 요구하는 것은 지나친 강제일까요? 이 백서의 판단은 **"법으로 일률 강제하기보다 계약 조건으로 요구하는 것이 합리적이며, 과도하지 않다"** 입니다.

- 정보의 주인은 국민(정보주체)이지만, 그 권리를 지킬 책임은 정보를 받은 기관에 있고 외주를 맡겨도 관리·감독 책임은 남습니다(개인정보보호법 제 26 조). 개인정보위도 외부 도구를 쓸 때의 안전조치 책임이 이용기관에 있다고 밝혔습니다[24].
- 외주 단계의 사고가 실제로 잇따랐습니다(침투경로 8~10).
- 보안서약서나 개인정보 처리 위탁 계약처럼, 보안 조건을 계약에 넣는 것은 이미 일반적인 관행입니다. 위 네 가지 장치를 함께 쓰면 업체 부담은 크게 줄어듭니다.

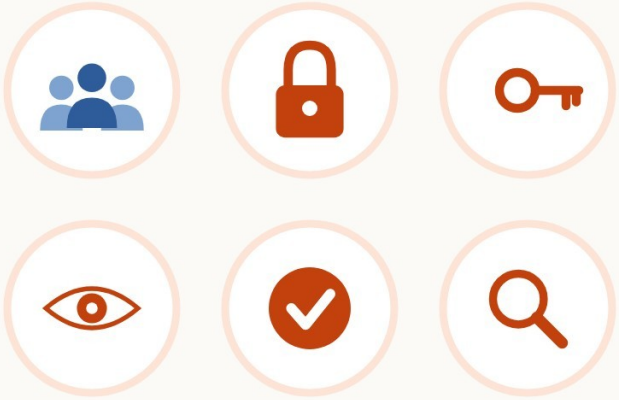
계약서 문구 예시
① **수집 도구:** 개인정보를 수집하는 경우 클라우드 보안인증을 받은 도구(국가정보원 '도입 가능 목록' 등재 서비스)를 사용한다. 다만 관계 지침이 허용하는 대체 절차나 예외 요건을 충족한 경우에 한하여 발주기관의 승인을 받아 다른 도구를 사용할 수 있다.
② **계정:** 발주기관이 제공하거나 승인한 계정으로 수집하며, 계약이 끝나면 즉시 권한을 회수한다.
③ **파기:** 종료 후 ○일 안에 파기하고 파기 증빙을 제출하며, 발주기관은 현장 확인을 할 수 있다.
④ **외부 업로드 금지:** 검사·변환·공유 목적이라도 원본을 외부 웹서비스에 올리지 않는다.
⑤ **사고 협조:** 사고가 나면 즉시 알리고 발주기관과 관계기관의 조사에 협조한다.

정책 제언

- **교육현장 예외를 보완합니다.** 학교 등 교육현장에 예외를 두더라도 2 단계 인증, 졸업·퇴직자 계정 정리, 접속 기록 확인 같은 최소 계정 보안 기준을 의무로 하고, 학생·교직원 개인정보를 받는 업무에는 예외를 적용하지 않는 방안을 검토합니다.
- 국정원 사이버보안 실태평가와 개인정보위 개인정보 보호수준 평가에 **'설문·신청 수집 도구와 외주업체 도구의 인증 여부'** 를 구체적인 점검 항목으로 둡니다.
- 개인정보위의 외부 설문도구 안내에 클라우드 보안인증 도구와의 관계를 분명히 하고, **개인 계정 운영 금지**를 명시합니다.
- 부처·광역자치단체가 인증 도구를 일괄 계약해 산하기관·학교에 제공하는 **공동 활용 모델**을 지원합니다.
- AI 요약·분석 기능을 탑재한 공공용 서비스에 대해 **숨은 명령(간접 프롬프트 인젝션) 대응**을 확인하는 평가 기준을 마련합니다.
- 위탁 관리·감독 기준에 발주기관이 외주업체의 수집 도구와 계정을 확인하는 절차를 구체화합니다.

Part 8.
국민 행동 지침

신청서 앞에서 지킬 10 가지



기관이 문을 바꾸는 데는 시간이 걸립니다. 그동안 국민 한 사람 한 사람이 바로 실천할 수 있는 수칙입니다.



도움 받을 곳

이럴 때	어디에	주소·전화
내 아이디·이메일 유출 여부 확인	털린 내 정보 찾기(개인정보위·KISA)	kidc.eprivacy.go.kr
개인정보 노출·유출 신고	개인정보침해 신고센터(KISA)	118 · privacy.kisa.or.kr
사칭 폼·피싱·해킹 피해 신고	경찰청 사이버범죄 신고시스템	ecrm.police.go.kr · 긴급 112
신분증 노출, 금융 명의도용 걱정	개인정보노출자 사고예방시스템(금감원)	pd.fss.or.kr
내 명의 휴대폰 개통 확인·차단	엠세이퍼 명의도용방지서비스	msafer.or.kr

이것만은 꼭

폼이 비밀번호·인증번호를 물으면 사기입니다. 구글도 모든 폼 아래에 "비밀번호를 제출하지 마세요"라고 경고합니다[17].

의심되면 멈추고, 기관 대표번호로 직접 확인하세요. 받은 문자·전화번호로 되묻지 마세요.

맺음말

설문·신청서는 행정과 기업 활동에서 가장 흔하고, 그래서 가장 쉽게 잊히는 문입니다. 지금까지의 사고는 대부분 설정 실수, 남겨진 자료, 털린 계정처럼 **기관이 통제하지 못한 곳**에서 일어났습니다. AI 는 이 작은 틈을 더 빨리, 더 많이 찾아냅니다.

해법은 복잡하지 않습니다. 국민 정보를 받는 문을 **국가가 검증한 문으로 바꾸고**, 외주에도 같은 기준을 요구하며, 국민은 의심스러운 신청서 앞에서 멈추는 것입니다. 사고가 공개된 뒤에는 이미 늦습니다.

부록 A. 용어 풀이

용어	쉬운 설명
클라우드 보안인증(CSAP)	공공기관에 클라우드 서비스를 제공하려는 사업자의 보안을 국가가 점검해 인증하는 제도
도입 가능 목록	국가정보원이 공개하는 「국가·공공기관 민간 클라우드 컴퓨팅서비스 도입 가능 목록」. 공공기관은 민간 클라우드를 쓸 때 이 목록의 서비스를 써야 함
SaaS	설치 없이 인터넷으로 빌려 쓰는 소프트웨어 서비스
피싱	진짜처럼 꾸민 메일·문자·화면으로 비밀번호나 개인정보를 빼내는 사기
정보탈취 악성코드	PC 에 저장된 비밀번호·로그인 상태·인증서를 훔쳐 외부로 보내는 악성코드
세션	로그인한 상태를 유지하는 정보. 이것을 훔치면 비밀번호 없이도 로그인한 것처럼 접속할 수 있음
2 단계 인증 / 패스키·보안키	비밀번호 외에 한 번 더 확인하는 인증. 패스키·보안키는 진짜 사이트에서만 작동해 피싱에 특히 강함
숨은 명령(간접 프롬프트 인젝션)	메일·문서·응답 속에 AI 에게 주는 명령을 숨겨 AI 비서를 조종하는 공격
AI 에이전트	목표를 주면 여러 도구를 스스로 쓰며 작업을 이어 가는 AI
웹셸	웹사이트 서버에 몰래 심어 서버를 원격으로 조종하는 악성 파일

부록 B. 출처

본문의 [번호]는 아래 목록과 대응합니다. 웹 자료는 모두 2026 년 11 월 7 일까지 원문 페이지에서 확인했습니다.

[1] (재)한국컨설팅산업재단 부설 개인정보보호진흥원·국회 박상혁 의원실, 「공공기관 온라인설문 개인정보 수집실태」 보도자료 및 붙임 조사결과(조사기간 2026.8.21.~10.5.).

[2] 뉴시스, 「6 개 지역서 학교 구글 계정 11 만개 해킹…"비번 360 만개 변경 완료"」, 2026.10.22. https://nwww.newsis.com/view/NISX20261022_0003837339

[3] 경향신문, 「[단독]10 만명 공직자 정보 유출…"파기 완료" 위탁업체 1 년 반 허위 보고, 권익위는 몰랐다」, 2026.10.21. https://www.khan.co.kr/article/202610211038011

[4] 보안뉴스, 「[더존비즈온 사태] 급여 계좌부터 가족 주민번호까지... 더존비즈온 해킹이 '중대 사고' 인 이유」, 2026.11.2. https://www.boannews.com/news/articleView.html?idxno=146948

[5] 보안뉴스, 「맑은소프트 개인정보 유출 규모 237 만건... 고객사 22 곳 불똥」, 2026.10.13. https://www.boannews.com/news/articleView.html?idxno=146361

[6] MBC, 「[단독] "'1 호기 명단', 보안 업체서 고유 식별값 대신 원본 파일 올려"」, 2026.11.5. https://imnews.imbc.com/news/2026/politics/article/6863333_36911.html

[7] Anthropic, "Disrupting the first reported AI-orchestrated cyber espionage campaign", 2025.11.13. https://www.anthropic.com/news/disrupting-AI-espionage

[8] Google Security Blog, "New research: How effective is basic account hygiene at preventing hijacking", 2019.5.17. https://security.googleblog.com/2019/05/new-research-how-effective-is-basic.html

[9] Google Threat Intelligence Group, "GTIG AI Threat Tracker: Advances in Threat Actor Usage of AI Tools", 2025.11.5. https://cloud.google.com/blog/topics/threat-intelligence/threat-actor-usage-of-ai-tools

[10] MBC, 「북한 배후 해킹그룹, 챗 GPT 로 군 신분증 위조··피싱 공격 시도」, 2025.9.15. https://imnews.imbc.com/news/2025/econo/article/6756090_36737.html

[11] 이현섭(법무법인 세움), 「구글폼 응답이 다른 응답자에게 보였다면 과태료 대상일까요? — 결정문 8 건의 기준」, 2026.10.19. https://datalaw.kr/posts/google-forms-survey-exposure-fine/

[12] 뉴시스, 「대전 학교 구글 비번 7 만개 '무단 변경' …졸업생·퇴직자도 피해 가능성」, 2026.10.13. https://nwww.newsis.com/view/NISX20261013_0003824309

[13] 국가정보원, 「국가 사이버보안 기본지침」(2026.5.1.) 제 2 조, 제 24 조의 3·제 24 조의 4. https://www.ncsc.go.kr/template/resources/file/nis_guide_lines_2023_1_31.pdf

[14] 경북도민일보, 「천하람 "국민사서함 3 만 8000 건 답변도 없이 폐기"」, 2026.10.29. https://www.hidomin.com/news/articleView.html?idxno=727010

[15] 보안뉴스, 「[단독] 北김수키, 국세청·네이버 사칭 공격 활개..계정 도용 주의보!」, 2025.3.2. https://www.boannews.com/news/articleView.html?idxno=136326

[16] Okta Threat Intelligence, "Okta observes v0 AI tool used to build phishing sites", 2025.7.1. https://www.okta.com/blog/threat-intelligence/okta-observes-v0-ai-tool-used-to-build-phishing-sites/

[17] Forbes(Davey Winder), "Google Forms Used In Password-Stealing Spree: What You Need To Know"(Zimperium 연구 인용), 2020.11.3. https://www.forbes.com/sites/daveywinder/2020/11/03/always-trust-google-here-are-256-password-stealing-reasons-you-shouldnt/

[18] Kaspersky, "Beware of Google Forms bearing crypto gifts", 2025.7.24. https://www.kaspersky.com/blog/google-forms-scam/53909/

[19] P. Reddy, A. S. Gujral, "EchoLeak: The First Real-World Zero-Click Prompt Injection Exploit in a Production LLM System", arXiv:2509.10540, 2025.9. https://arxiv.org/abs/2509.10540

[20] Noma Security, "GeminiJack: the Google Gemini zero-click vulnerability leaked Gmail, Calendar and Docs data", 2025.12.8. https://noma.security/blog/geminijack-google-gemini-zero-click-vulnerability

[21] Google, "Google Workspace's continuous approach to mitigating indirect prompt injections", 2026.4.2. https://blog.google/security/google-workspaces-continuous-approach-to-mitigating-indirect-prompt-injections/

[22] 이스트시큐리티 ESRC, 「기능별 C2 서버를 운용하는 Kimsuky 그룹의 새로운 LNK 악성코드 등장」, 2026.9.9. https://www.estsecurity.com/public/security-info/column/view/1183075

[23] 보안뉴스, 「[대한민국 털렸다] '프랙' 보고서 사실이었다...행안부 온나라 시스템 등 해킹 확인」, 2025.10.17. https://www.boannews.com/news/articleView.html?idxno=139807

[24] 개인정보보호위원회, 「외부 설문도구 이용 시 개인정보 처리 준수 사항에 대해 보다 명확히 안내하겠습니다」 보도참고자료, 2026.10.16. https://www.pipc.go.kr/np/cop/bbs/selectBoardArticle.do?bbsId=BS074&mCode=C020010000&nttId=12585

[25] 미디어오늘, 「직원 가족·입사 지원자 개인정보 '탈탈' 털린 콜센터 업체」, 2026.4.23. https://www.mediatoday.co.kr/news/articleView.html?idxno=333978

[26] Mandiant(Google Cloud), "UNC5537 Targets Snowflake Customer Instances for Data Theft and Extortion", 2024.6.10. https://cloud.google.com/blog/topics/threat-intelligence/unc5537-snowflake-data-theft-extortion

[27] 보안뉴스, 「[더존비즈온 사태] 11월 5일 유출 의심 기업 현황... 서울시 육아종합지원센터 유출 가능성」, 2026.11.5. https://www.boannews.com/news/articleView.html?idxno=147019

[28] 동아일보, 대통령 순방단 개인정보 유출 보도, 2026.11.3. https://www.donga.com/news/Politics/article/all/20261103/134957843/1

[29] Google Threat Intelligence Group, "The Cost of a Call: From Voice Phishing to Data Extortion", 2025.6.4(2025.8 갱신). https://cloud.google.com/blog/topics/threat-intelligence/voice-phishing-data-extortion

[30] 경향신문, 「경찰 "북한 해커 조직, 국내 10여 개 방산업체 기술 탈취"」, 2024.4.23. https://www.khan.co.kr/article/202404231200001

[31] 뉴스1, 「토종 1위 ERP 더존비즈온 해킹… 고객사 민감정보 유출 가능성」, 2026.10.26. https://www.news1.kr/it-science/security-hacking/6331870

[32] 보안뉴스, 「거제시 이어 경기도 산하 홈피까지 개인정보 노출 위험 드러나... 지자체 보안 부실은 외주 탓?」, 2024.6.21. https://www.boannews.com/news/articleView.html?idxno=130782

[33] 보안뉴스, 「'사칭' 이라던 자비스, 실제 뚫렸다... 공동인증서·결제 정보 등 유출 확인」, 2026.11.6. https://www.boannews.com/news/articleView.html?idxno=147080

[34] KBS, 「[단독] "여론조사업체 15곳 중 14곳 법 위반" 개인 정보 '구멍'…실태도 '깜깜'」, 2025.4.25. https://news.kbs.co.kr/news/pc/view/view.do?ncd=8238025

[35] SBS, 「[단독] 북, 총선 전 여론조사 기관 공격…선거 혼란 노렸나」, 2024.5.24. https://news.sbs.co.kr/news/endPage.do?news_id=N1007658916

[36] MTN 머니투데이방송, 「[단독] 더존비즈온, 7월 고객센터도 뚫렸다...개인정보 8개 항목 유출」, 2026.11.5. https://news.mtn.co.kr/article/2026110511112249187

[37] 경향신문, 「네이버 인기 블로그 계정 해킹하고 판매한 일당 검거」, 2022.11.16. https://www.khan.co.kr/article/202211161628001

[38] 경향신문, 「고객정보 306만건 유출 '모두투어'…과징금 7억 5000만원」, 2025.3.13. https://www.khan.co.kr/article/202503131225001

[39] Google Cloud, "April 2023 Threat Horizons Report". https://services.google.com/fh/files/blogs/gcat_threathorizons_full_apr2023.pdf

[40] CloudSEK, "Compromising Google Accounts: Malwares Exploiting Undocumented OAuth2 Functionality for session hijacking", 2023.12.29. https://www.cloudsek.com/blog/compromising-google-accounts-malwares-exploiting-undocumented-oauth2-functionality-for-session-hijacking

[41] Microsoft Threat Intelligence, "From cookie theft to BEC: Attackers use AiTM phishing sites as entry point to further financial fraud", 2022.7.12. https://www.microsoft.com/en-us/security/blog/2022/07/12/from-cookie-theft-to-bec-attackers-use-aitm-phishing-sites-as-entry-point-to-further-financial-fraud/

[42] 국가법령정보센터, 「클라우드컴퓨팅서비스 보안인증에 관한 고시」(과학기술정보통신부고시 제 2023-4 호, 2023.1.31.). https://www.law.go.kr/행정규칙/클라우드컴퓨팅서비스보안인증에관한고시

[43] 윤대균(아주대학교), 「CSAP 및 FedRAMP 최근 동향」, 디지털서비스 이슈리포트 2024-07, 조달청, 2024.7.31. https://www.digitalmarket.kr/web/board/BD_board.view.do?domainCd=2&bbsCd=1030&bbscttSeq=20240731093432396&monarea=00008

[44] 국가정보원, 「국가·공공기관 민간클라우드 컴퓨팅서비스 도입 가능목록」(2026.9.30. 기준).

[45] 디지털투데이, 「국정원, 국가·공공기관 도입 가능 클라우드 서비스 89 개 공개」, 2023.8.11. https://www.digitaltoday.co.kr/news/articleView.html?idxno=484572

[46] 뉴스 1, 「국정원, 공공 클라우드 보안체계 구체화…등급별 이용조건 공개」, 2026.9.22. https://www.news1.kr/it-science/security-hacking/6297831

[47] 전자신문, 「보안인증 없는 구글폼…개보위 사업에 쓰였다」, 2026.10.15. https://www.etnews.com/20261015000353

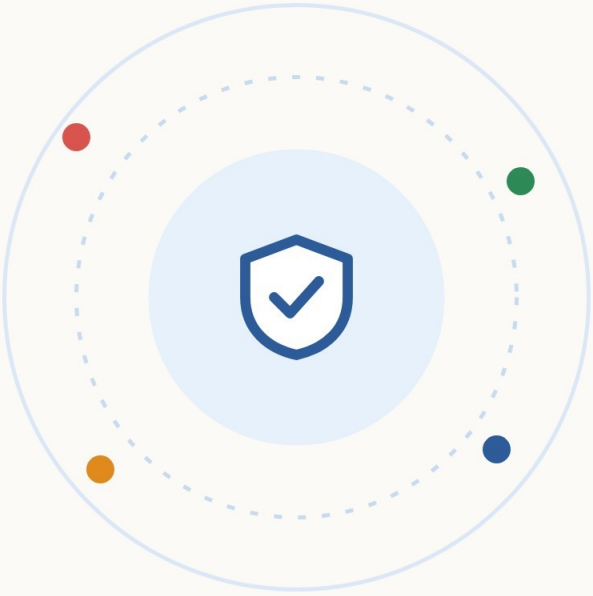
[48] 교육부, 「교육부 정보보안 기본지침」(2023.11.21.) 제 41 조제 7 항.

제목	AI 시대, 설문·신청서가 해킹의 문이 됩니다 — 설문·신청·수집 단계의 보안 위협과 대응
발간번호	2026-11-02
발간일	2026 년 11 월 10 일
발간처	한국컨설팅산업재단 | 개인정보보호진흥원
문의	개인정보보호진흥원 02-501-2906 · cs@kcf-korea.org

이 백서의 내용은 출처를 밝히고 자유롭게 인용할 수 있습니다.

국민 · 공공기관 · 기업을 위한 백서

AI 시대, 설문·신청서가 해킹의 문이 됩니다



설문·신청서 한 장에도 국민의 정보가 담깁니다.
안전한 수집이 신뢰받는 행정과 서비스의 출발점입니다.

개인정보보호진흥원

(재)한국컨설팅산업재단 부설 · 서울특별시 송파구 양재대로71길 20-30, 2층

02-501-2906
전화

cs@kcf-korea.org
이메일

02-558-5146
팩스

www.kcf-korea.org/privacy-center
웹사이트

진흥원 바로가기

(재)한국컨설팅산업재단 T 02-555-9091 · F 02-455-0090 · www.kcf-korea.org

발간번호 2026-11-02 · 발간일 2026. 11. 10.

비매품 · 출처를 밝히고 인용할 수 있습니다